API 与数据安全规范

[SEC-001] API Key 不得写入源代码、版本库、聊天记录、截图或前端响应，只能由服务端环境变量或密钥服务提供。

[SEC-002] 开发、测试和演示环境使用不同的 API Key。正常轮换周期不超过 90 天，成员离组或怀疑泄漏时立即轮换。

[SEC-003] 向公网模型发送数据时，只允许发送完成任务所需的最小片段。密码、密钥、个人敏感信息和真实业务机密禁止外发。

[SEC-004] 发现密钥泄漏后，应立即停用密钥、检查异常调用和账单，并在 30 分钟内通知项目安全负责人。

[SEC-005] 大模型无数据库凭据，也不得直接执行 SQL。任何 SQL 必须通过本地 AST、权限、超时和行数校验。